

Self-Review: Findings & Fix

Each finding gets a one-line verdict — accept (it's a real gap) or push back (constrained/acceptable). One is fixed in the code below.

#	Finding (pillar)	Verdict	One-line reply
F1	LabRole is a broad shared role, not least-privilege (<i>Security</i>)	PUSH BACK	Learner Lab denies iam:CreateRole, so a scoped role isn't possible here — I'd attach a least-privilege role in a real account.
F2	Public GET /weather is auth NONE with no throttling (<i>Security / Cost</i>)	ACCEPT	Anonymous access is required by the course, so I cap abuse with throttling — this is the fix below.
F3	No CloudWatch Logs retention or tracing (<i>Op. Excellence</i>)	ACCEPT	Logs default to never-expire; I'd add a log group with retention and enable X-Ray — low effort, real observability win.
F4	Failed DynamoDB write returns 500, no retry/DLQ (<i>Reliability</i>)	PUSH BACK	For a read-through weather cache this is acceptable; errors surface as JSON. I'd add a DLQ if the write became async or critical.
F5	DynamoDB + API GW + Lambda all scale to zero (<i>Cost</i>)	ACCEPT	No change — this is a strength, not a gap; idle cost is effectively \$0.
F6	Secret has no automatic rotation (<i>Security</i>)	PUSH BACK	OpenWeatherMap keys have no rotation API; documented manual rotation is acceptable for this workload.

The fix I'd push — F2: throttle the public endpoint

Why this one: it's the highest-risk item. An open, unauthenticated URL triggers compute *and* a paid third-party call on every hit, so a bursty or abusive caller can run up Lambda and OpenWeatherMap usage. Adding stage-level throttling caps the blast radius and runaway cost in a 4-line Terraform change. **Pillars: Security + Cost.**

Before

```
resource "aws_apigatewayv2_stage" "default" {
  api_id      = aws_apigatewayv2_api.http.id
  name        = "$default"
  auto_deploy = true
}
```

After — now in main.tf

```
resource "aws_apigatewayv2_stage" "default" {
  api_id      = aws_apigatewayv2_api.http.id
  name        = "$default"
  auto_deploy = true

  default_route_settings {
    throttling_rate_limit = 10 # req/s
    throttling_burst_limit = 5 # burst
  }
}
```

Status — pushed: the default_route_settings block is now committed in phase2-apigateway/main.tf. To go live: `terraform apply` (1 to change), then verify with a quick loop of `curl` calls — beyond ~10 req/s the API returns **HTTP 429 Too Many Requests**, confirming the throttle is active.